

Finwiser — Technical Documentation

HyKr Build Challenge 2026 · MVP Phase Submission Last updated: 2026-05-13 · Author: Chandrachuda Sarma, Founder A detailed engineering appendix with full module deep-dives, formula derivations, and operational runbook (`Finwiser_Technical_Overview.md`) is browsable alongside the production source at the **Codebase Explorer** → finwiser.org/codebase/.

SEBI Registered Investment Adviser — INA000021331 · FIU-registered entity · Sahamati ReBIT 2.1.0 certified AA integration · OCI Mumbai + MongoDB Atlas Mumbai · Flutter Android in Google Play Closed Testing

1. Product Summary

Finwiser is a working Android reference app on a production backend that:

- Ingests consented multi-source financial data — Account Aggregator, Gmail, PDF statements, credit bureau.
- Normalises it into a unified ledger.
- Runs categorisation, cashflow analytics, and per-scheme mutual-fund intelligence.
- Produces goal-linked allocation recommendations under SEBI RIA suitability.

All financial logic runs server-side; the Flutter Android app is a thin reference client.

2. Tech Stack

Layer	Stack
Mobile	Flutter ≥ 3 / Dart ≥ 3 · <code>provider</code> (state) · <code>get_it</code> (DI) · <code>dio</code> (network) · <code>hive</code> (offline) · <code>flutter_secure_storage</code> · <code>eventsourcing</code> (SSE) · <code>firebase_messaging</code> · <code>fl_chart</code> · Rive
Backend	Node.js 20 LTS · Express 4 · Mongoose 8 · Bull (queues) · Redis (managed)
Database	MongoDB Atlas (Mumbai · M10+) · CSFLE for PAN / mobile / financial PII
Data sources	Account Aggregator (Saafe + Finvu) · Gmail Push via Pub/Sub · PDF (<code>pdf-parse</code>) · Experian via IDSPay
Market data	AMFI instrument master · <code>mfapi.in</code> NAV history
Infrastructure	OCI Mumbai (Ubuntu 22.04 LTS) · PM2 supervisor
Security	TLS 1.2+ · mTLS via SahamatiNet · JWE/JWS (<code>node-jose</code>) · JWT + JWKS · Helmet · <code>express-rate-limit</code> (Redis)
Observability	Pino JSON · Sentry · Prometheus · Datadog · Slack + PagerDuty alerts

Non-obvious picks. MongoDB over Postgres — evolving FI shapes absorbed without migrations; CSFLE for PII. **OCI Mumbai over AWS Mumbai** — SEBI / RBI residency; predictable egress; free-tier MAU. **PM2 fork mode over containers** — single service, single region; no container overhead at current scale.

3. Architecture

Four logical modules within a single Node.js service, with explicit data-flow boundaries. The monolith is a deliberate choice at current scale — DI-enforced module boundaries keep responsibilities sharp without distributed-system overhead.

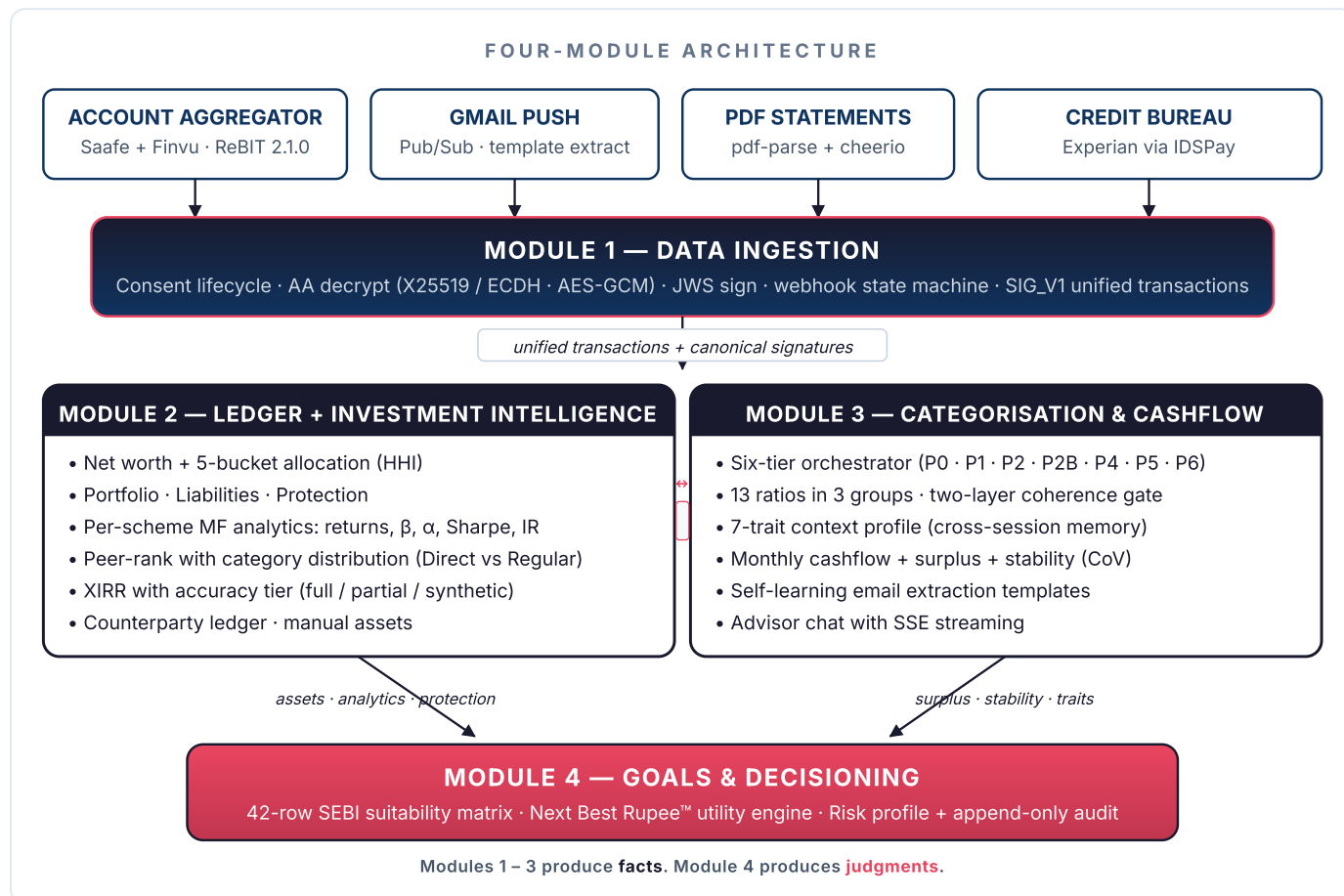


Figure 1 — Four-module architecture. Ingestion → Ledger × Categorisation → Decisioning.

- **Module 1 — Data Ingestion.** External acquisition: AA fetch lifecycle, Gmail Push, PDF parsing, credit-bureau pulls. Outputs a unified transaction stream with canonical signatures for cross-source dedup.
- **Module 2 — Ledger + Investment Intelligence.** Net worth, 5-bucket allocation, per-scheme MF analytics (returns, β , α , Sharpe, IR), peer rank, XIRR with accuracy tiering.
- **Module 3 — Categorisation & Cashflow.** Six-tier categorisation orchestrator (P0–P6), ratio engine with coherence gate, 7-trait context profile, advisor chat over SSE.
- **Module 4 — Goals & Decisioning.** Goal lifecycle, 42-row SEBI mutual-fund suitability matrix, Next Best Rupee allocation engine — ranks active goals by a structured multiplicative utility and emits named rationale codes (`must_have_bias` , `emergency_underfunded` , `high_urgency` , `within_policy_bands` , `stable_surplus` , `progress_momentum`) so every recommendation is auditable and explainable.

Deployment view.

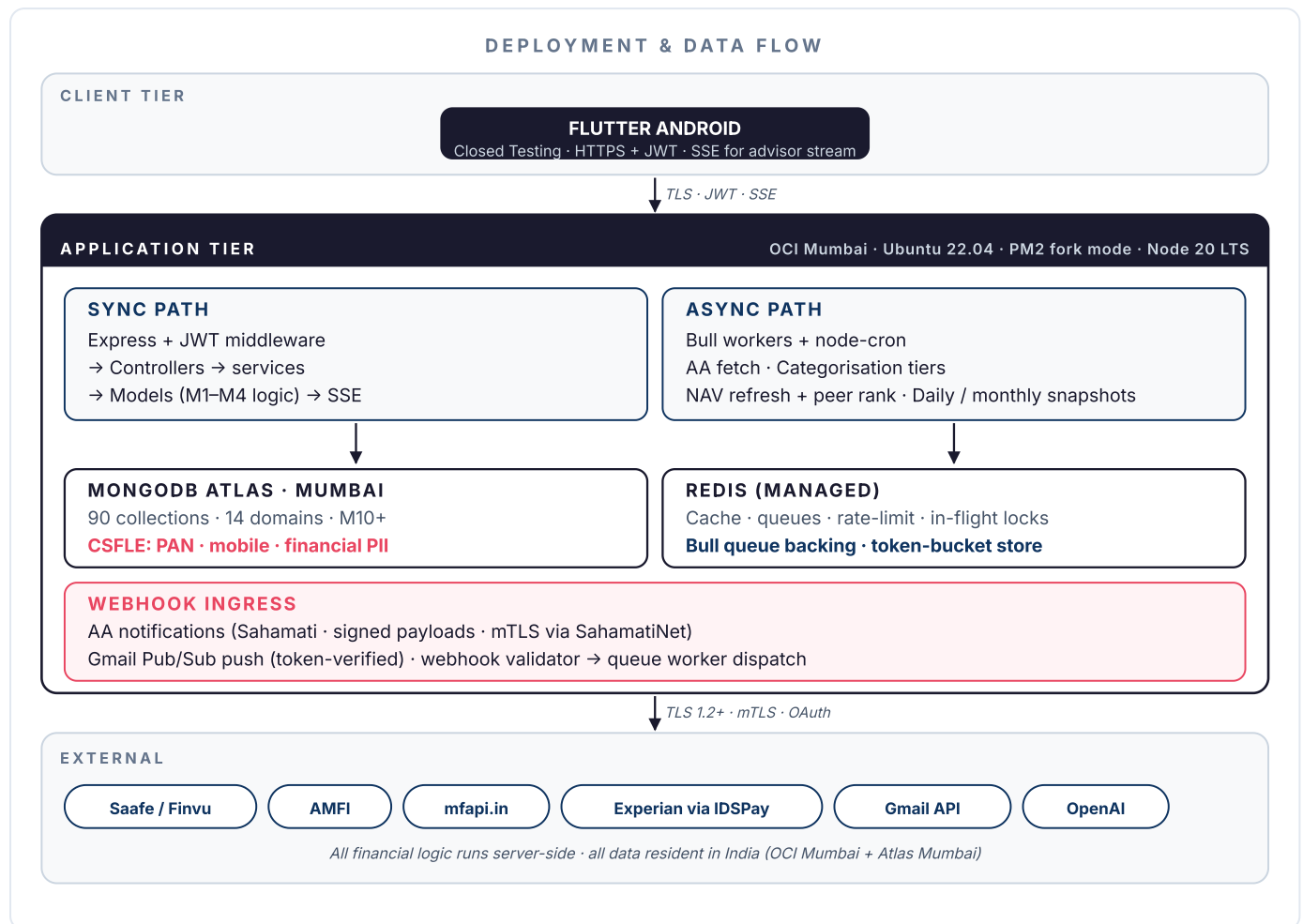


Figure 2 — Deployment topology and request paths (sync vs async, webhook ingress, external dependencies).

Data model. ~90 collections across 14 domains (AA pipeline, ledger, market data, categorisation, counterparty, goals, audit, etc.). Tiered TTL — 24h / 30d / 90d / ~7 years — depending on regulatory class.

4. Security & Compliance

Stack-level controls (TLS, mTLS, JWE/JWS, JWT/JWKS, Helmet, rate-limit, CSFLE) are listed in §2. The operational posture on top of that:

- **AA payload contract** — JWE (ECDH, AES-GCM) + JWS per ReBIT 2.1.0. Validated by the Sahamati certification harness (72/72 scenarios), which runs in CI on every backend PR.
- **CSFLE that cannot silently no-op.** The encryption plugin refuses to start in production without a configured master key, so "plaintext PII at rest" is structurally impossible — not a config-default risk.
- **Idempotency at every write boundary.** Cross-source transaction signatures, atomic `findOneAndUpdate` on snapshots, MongoDB-backed distributed locks for cron and webhook fan-out. Every state transition is replayable.
- **Two-tier audit trail.** Operational `calculationauditlogs` (90-day TTL) for decision replay; regulatory `legalretentionartifacts` (~7-year, pre-save immutable) for SEBI RIA Reg. 19.
- **Defence in depth.** Per-call PII audit logging; mock-credential refuse-to-boot guard in production; AA fair-use throttle enforced before the network call (not at the response).

5. Worked Example

One first connection, traced end to end. At each stop: the mechanisms that run — and what a naïve implementation gets wrong without them. A wrong number here isn't a bug; it's bad advice someone acts on with real money.

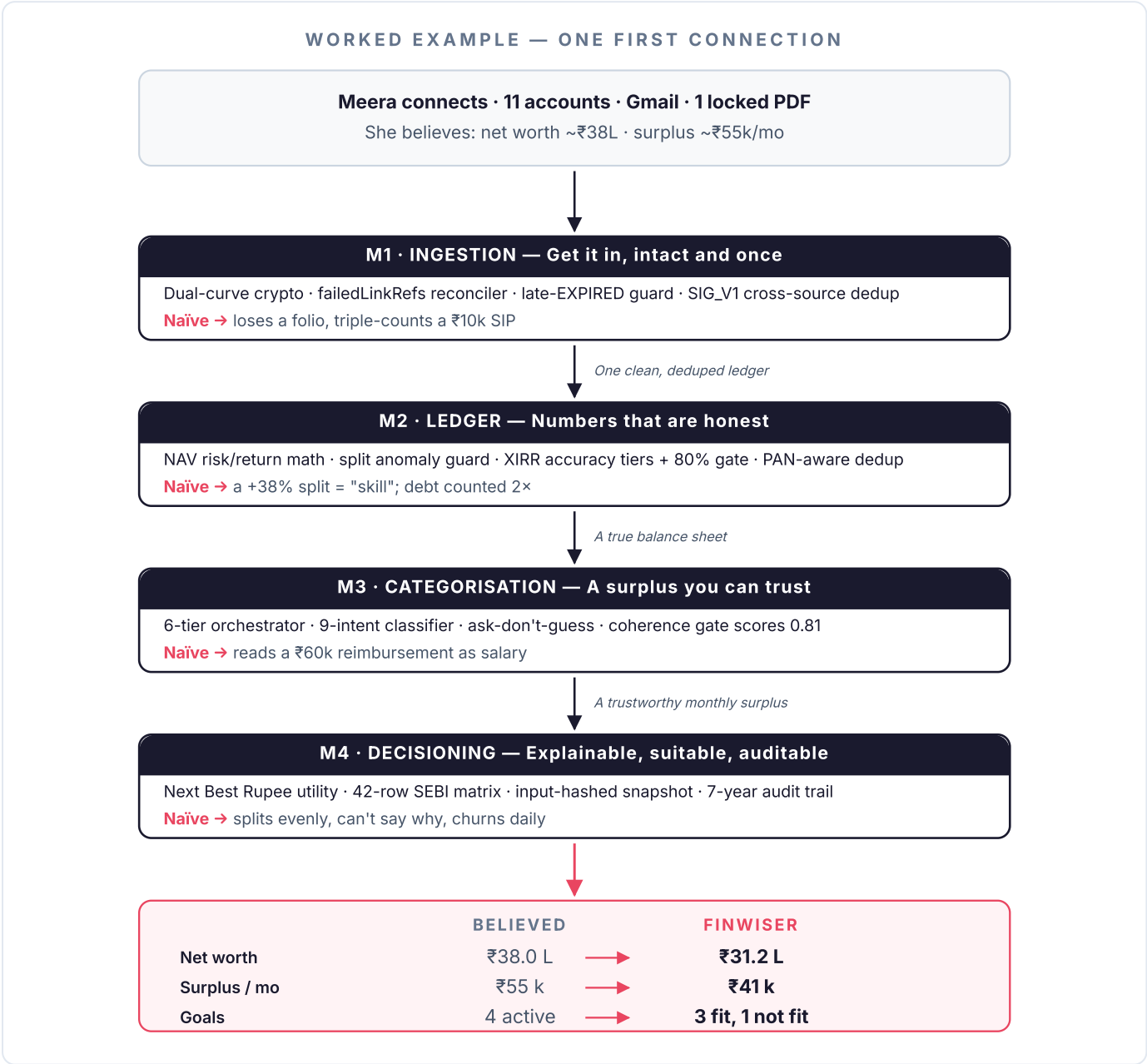


Figure 3 — One first connection, traced through all four modules: the mechanism at each stop, and what a naïve build gets wrong without it.

Meera asked one question — "where do I actually stand?" — and every step between her tap and the answer had a dozen ways to be quietly, confidently wrong. Closing that gap is what the engineering is for.

6. Deployment & Reviewer Access

Delivery. SSH + `git pull` + `pm2 restart`. Health endpoint `GET /health`. Boot 3.5–8.5 s; rollback is `git revert` + redeploy.

Environments. Three tiers — local dev (Cloudflared exposes the dev host to AA sandbox), UAT / sandbox (isolated DB, sandbox vendors), and production. Database isolation enforced by `DB_NAME` (`main` / `finvu` / `saafe`).

Scaling posture. Single-node by design at current MAU. Distributed locks are MongoDB-backed, so adding a second OCI instance sharing Bull/Redis is an operational change, not an architectural one.

Reviewer access.

- **Codebase Explorer:** finwiser.org/codebase/ — browse the full production backend (modules, services, models, routes) and the engineering appendix without a GitHub clone. Provided in lieu of a public repo link.
- **Android app:** Google Play Closed Testing → link in the submission form.
- **Test login:** mobile `9876543210` · OTP `123456`. The seeded test account bypasses the production onboarding flow so reviewers land directly on a populated ledger.
- **Live ingestion path.** Use the **Fresh AA fetch** action on the home screen to see the end-to-end pipeline (~60 s).

Three steps after login:

1. **Net Worth tab** → balance sheet, 5-bucket allocation, MF holdings with peer-percentile rank and XIRR accuracy tier.
2. **Goals tab** → tap any goal to see the Next Best Rupee rationale and structured factor breakdown.
3. **Advisor tab** → ask *"where am I spending the most?"* or *"should I increase my emergency fund?"* — responses stream via SSE.

Technical questions: `chandrachudasarma@gmail.com`

7. Limitations

- **Android only.** iOS deferred.
- **Closed Testing.** Not yet a public Play Store release.
- **Single region.** OCI Mumbai. DR documented; production is not multi-region.
- **Credit Bureau** (Experian via IDSPay) live since 2026-05-11 — early production volume.
- **AA throttle** of 45 calls per FIP per month applies under Sahamati fair-use during onboarding.

Full architecture, complete data model, cron schedule, retention tiers, security implementation detail, and decomposition history live in the **Detailed Architecture Appendix** (`Finwiser_Technical_Overview.md`), browsable via the **Codebase Explorer** → finwiser.org/codebase/.

Registration granted by SEBI, certification by Sahamati, and registration with FIU India in no way guarantee the performance of the intermediary or provide any assurance of returns to investors. SEBI RIA registration is mandatory for advisory services; it is not an endorsement of the platform.